Chapter 13 Intro to Networking Exam

Candidate: Dunkan Gibson (dunkan.gibson)
Date: 11/16/2021 6:08:17 pm • Time spent: 21:41

Score: 95% Passing Score: 80%

Question 1: ✔ Correct

A group of salesmen in your organization would like to access your private network through the internet while they are traveling. You want to control access to the private network through a single server.

Which solution should you implement?

- IPS
- IDS
- RADIUS
- ➡ VPN concentrator
- DMZ

EXPLANATION

With a remote access VPN, a server on the edge of a network (called a VPN concentrator) is configured to accept VPN connections from individual hosts. Hosts that are allowed to connect using the VPN connection are granted access to resources on the VPN server or the private network.

A demilitarized zone (DMZ), also called a screened subnet, is a buffer network (or subnet) that sits between the private network and an untrusted network (such as the internet). A RADIUS server is used to centralize authentication, authorization, and accounting for multiple remote access servers. However, clients still connect to individual remote access servers.

An intrusion detection system (IDS) is a special network device that can detect attacks and suspicious activity. A passive IDS monitors, logs, and detects security breaches, but takes no action to stop or prevent attacks. An active IDS (also called an intrusion protection system, or IPS) performs the functions of an IDS, but can also react when security breaches occur.

REFERENCES

LabSim for Network Pro, Section 13.7.

Question 2: ✔ Correct

You have a web server that will be used for secure transactions for customers who access the website over the internet. The web server requires a certificate to support SSL.

Which method would you use to get a certificate for the server?

- Create your own internal PKI to issue certificates.
- Have the server generate its own certificate.
- Run a third-party tool to generate the certificate.
- ➡ Obtain a certificate from a public PKI.

EXPLANATION

Computers must trust the CA that issues a certificate. For computers that are used on the internet and accessible to public users, obtain a certificate from a public CA such as VeriSign. By default, most computers trust well-known public CAs.

Use a private PKI to issue certificates to computers and users within your own organization. You configure computers to trust your own PKI, so certificates issued by your internal CAs are automatically trusted. A certificate generated by a server is called a self-signed certificate. A self-signed certificate provides no proof of identity because any other server can claim to be that server just by issuing itself a certificate.

REFERENCES

LabSim for Network Pro, Section 13.5.

Question 3: ✔ Correct

Which type of malware monitors your actions?

- Worm
- Virus
- Spyware
- Trojan horse

EXPLANATION

Spyware monitors the actions performed on a machine and then sends the information back to its originating source.

A virus is a program that attempts to damage a computer system and replicate itself to other computer systems. A worm is a self-replicating program that can be designed to do any number of things, such as negatively impacting network traffic. A Trojan horse is a malicious program that is disguised as legitimate software.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 4: ✔ Correct

Users in your organization receive email messages that inform them that suspicious activity has been detected on their bank account. They are directed to click a link in the email to verify their online banking username and password. The URL in the link is in the .ru top-level DNS domain.

What kind of attack has occurred?

- Virus
- Open SMTP relay
- Buffer overflow
- ➡ Phishing

EXPLANATION

A phishing scam uses an email pretending to be from a trusted organization and asks you to verify personal information or send money. In a phishing attack:

- A fraudulent message that appears to be legitimate is sent to a target.
- The message requests that the target visit a fraudulent website that also appears to be legitimate. Graphics, links, and web pages look almost identical to the legitimate websites the attacker is trying to represent.
- The fraudulent website requests that the victim provide sensitive information, such as an account number and password.

An SMTP relay is an email server that accepts mail and forwards it to other mail servers. In a buffer overflow attack, a program overruns the buffer's boundary while writing data to a memory buffer and writes data in adjacent memory addresses.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 5: ✔ Correct

Telnet is inherently insecure because its communication is in plaintext and is easily intercepted. Which of the following is an acceptable alternative to Telnet?

- SHTTP
- ➡ SSH
- Remote Desktop
- SLIP

EXPLANATION

SSH (Secure Shell) is a secure and acceptable alternative to Telnet. SSH allows secure interactive control of remote systems. SSH uses RSA public key cryptography for both connection and authentication. SSH uses the IDEA algorithm for encryption by default, but is able to use Blowfish and DES.

Remote Desktop, while a remote control mechanism, is limited to a few versions of Windows and is not very secure.

REFERENCES

LabSim for Network Pro, Section 13.6.

Question 6: ✔ Correct

As the victim of a Smurf attack, what protection measure is the most effective during the attack?

- Updating your anti-virus software
- ➡ Communicating with your upstream provider
- Turning off the connection to the ISP
- Blocking all attack vectors with firewall filters

EXPLANATION

The most effective protection measure the victim of a Smurf attack can perform during an attack is to communicate with upstream providers. A simple phone call to request filtering on your behalf can weaken the effectiveness of a Smurf attack.

Turning off the connection to the ISP will result in the same effect of the Smurf attack itself, denial of service. Whether you disconnect or the attack disconnects you, your network will be unable to use its internet pipeline. Blocking all attack vectors with firewall filters will usually result in a self-imposed denial of service since most Smurf attacks produce thousands of attack vectors for the inbound flooding packets. Updating your anti-virus software has no effect on a Smurf attack.

REFERENCES

LabSim for Network Pro, Section 13.8.

Question 7: ✔ Correct

Which of the following attacks is a form of software exploitation that transmits or submits a longer stream of data than the input variable is designed to handle?

- Data diddling
- Smurf
- Time of check/time of use (TOC/TOU)
- ➡ Buffer overflow

EXPLANATION

A buffer overflow occurs when software code receives more input than it was designed to handle and the code's programmer failed to include input validation checks. When a buffer overflow occurs, the extra data is pushed into the execution stack and processed with the security context of the system itself. In other words, a buffer overflow attack often allows the attacker to perform any operation on a system.

TOC/TOU is an attack where the results of the attack are realized or initiated at a time or event after the attack itself is perpetrated. Data diddling is the purposeful altering of data. A smurf attack is a form of distributed reflective denial of service.

REFERENCES

LabSim for Network Pro, Section 13.4.

Question 8: ✔ Correct

Which of the following are methods for providing centralized authentication, authorization, and accounting for remote access? (Select two.)

- [ ] PKI
- [ ] 802.1x
- [ ] AAA
- [x] RADIUS
- [ ] EAP
- [x] TACACS+

EXPLANATION

Both RADIUS and TACACS+ are protocols used for centralized authentication, authorization, and accounting used with remote access. Remote access clients send authentication credentials to remote access servers. Remote access servers are configured as clients to the RADIUS or TACACS+ servers and forward the authentication credentials to the servers. The servers maintain a database of users and policies that control access for multiple remote access servers.

AAA stands for authentication, authorization, and accounting. AAA is a generic term that describes the functions performed by RADIUS/TACACS+ servers. A Public Key Infrastructure (PKI) is a system of certificate authorities that issue certificates. 802.1x is an authentication mechanism for controlling port access. 802.1x uses RADIUS/TACACS+ servers. EAP is an authentication protocol that allows the use of customized authentication methods.

REFERENCES

LabSim for Network Pro, Section 13.5.

Question 9: ✔ Correct

An attacker has obtained the logon credentials for a regular user on your network. Which type of security threat exists if this user account is used to perform administrative functions?

- Impersonation
- ➡ Privilege escalation
- Social engineering
- Replay

EXPLANATION

Privilege escalation allows a user to take advantage of a software bug or design flaw in an application to gain access to system resources or additional privileges that are typically not available to normal users. Examples of privilege escalation include:

- A user accessing a system with a regular user account that is able to access functions reserved for higher-level user accounts (such as administrative features).
- A user who is able to access content that should be accessible only to a different user.
- A user who should have only administrative access being able to access content that should only be accessible to a regular user.

Privilege escalation does not occur when a user is able to steal or hack administrator credentials, and is therefore able to access administrative functions. Privilege escalation is accessing features with an account that normally should not have access to those features.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 10: ✔ Correct

A user named Bob Smith has been assigned a new desktop workstation to complete his day-to-day work. The computer runs Windows 7.

When provisioning Bob's user account in your organization's domain, you assigned an account name of **BSmith** with an initial password of **bw2Fs3d**.

At his first logon, Bob is prompted to change his password, so he changes it to **Fido**, the name of his dog.

What should you do to increase the security of Bob's account? (Select two.)

- [ ] Configure user account names that are not easy to guess.
- [x] Train users not to use passwords that are easy to guess.
- [ ] Upgrade the workstation to Windows 8.
- [ ] Do not allow users to change their own passwords.
- [x] Require users to set a stronger password upon initial logon.

EXPLANATION

In this scenario, a weak password that is easy to guess has been used. To prevent this from happening, you should:

- Require strong passwords on user accounts. In this example, **Fido** is a weak password because it is short and doesn't contain numbers or other non-alphabetic characters.
- Train users not to use passwords that are easy to guess. In this example, the user's password could very likely be guessed using basic reconnaissance techniques on social media websites.

You should allow users to set their own passwords. If you don't, then both the administrator and the user know the password, which is a poor security practice. Using the type of user account names that are shown in this scenario is generally considered an acceptable security practice. The security provided by Windows 7 is comparable to that provided by Windows 8.

REFERENCES

LabSim for Network Pro, Section 13.4.

Question 11: ✔ Correct

Which of the following is a secure doorway that can be used with a mantrap to allow easy exit, but actively prevent re-entrance through the exit portal?

- Egress mantraps
- ➡ Turnstiles
- Locked doors with interior unlock push-bars
- Electronic access control doors

EXPLANATION

Turnstiles allow easy egress from a secured environment but actively prevent re-entrance through the exit portal. Turnstiles are a common exit portal used with entrance portal mantraps. A turnstile cannot be used to enter into a secured facility, as it only functions in one direction.

Egress mantraps are not easy egress portals. Plus, they are a tremendous unnecessary expense and administrative burden. Any form of door, including self-locking doors with push-bars or credential readers, can be hijacked to allow an outsider to enter.

REFERENCES

LabSim for Network Pro, Section 13.1.

Question 12: ✔ Correct

Which of the following could easily result in a denial of service attack if the victimized system had too little free storage capacity?

- ➡ Spam
- Impersonation
- Replay attack
- Sniffing

EXPLANATION

Spam could easily result in a denial of service attack if the victimized system had too little free storage capacity. If too much spam is received by a system that does not have automatic filters or before a human can identify and purge spam, it is possible to consume all available storage space on the system and cause a system shutdown. This is a type of denial of service attack.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 13: ✔ Correct

Which of the following describes a man-in-the-middle attack?

- A person over the phone convinces an employee to reveal their logon credentials.
- ➡ A false server intercepts communications from a client by impersonating the intended server.
- An IP packet is constructed that is larger than the valid size.
- Malicious code is planted on a system, where it waits for a triggering event before activating.

EXPLANATION

A false server intercepts communications from a client by impersonating the intended server is a form of man-in-the-middle attack.

Convincing an employee over the phone to reveal his logon credentials is an example of a social engineering attack. Constructing an IP packet which is larger than the valid size is a land attack (a form of DoS). Planting malicious code on a system where it waits for a triggering event before activating is a logic bomb.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 14: ✔ Correct

An attacker uses an exploit to push a modified hosts file to client systems. This hosts file redirects traffic from legitimate tax preparation sites to malicious sites to gather personal and financial information.

What kind of exploit has been used in this scenario? (Select two. Both responses are different names for the same exploit.)

- [ ] Reconnaissance
- [x] Pharming
- [x] DNS poisoning
- [ ] Man-in-the-middle
- [ ] Domain name kiting

EXPLANATION

DNS poisoning (also known as DNS cache poisoning or Pharming) occurs when a name server receives malicious or misleading data that incorrectly maps host names and IP addresses.

In a DNS poisoning attack:

- Incorrect DNS data is introduced into the cache of a primary DNS server.
- The incorrect mapping is made available to client applications.
- Traffic is redirected to incorrect sites for phishing purposes.

Reconnaissance is used to gather information for an attack. The goal is to obtain DNS records that identify computer names and IP addresses in a network. Domain name kiting occurs when spammers exploit domain registration by taking advantage of the five-day grace period for a newly registered domain name to acquire domains and never pay for their registration. Attackers accomplish this task by unregistering a domain name just before the grace period is up and then immediately re-registering the domain name. Man-in-the-middle attacks are used to intercept information passing between two communication partners.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 15: ✔ Correct

IPsec is implemented through two separate protocols. What are these protocols called? (Select two.)

- [x] ESP
- [ ] EPS
- [x] AH
- [ ] L2TP
- [ ] SSL

EXPLANATION

IPsec is implemented through two separate protocols, IP Authentication Header and IPsec Encapsulating Security Payload. IPsec AH provides authentication and non-repudiation services to verify that the sender is genuine and the data has not been modified in transit. IPsec ESP provides data encryption services for the data within the packet.

IPsec SSL and IPsec EPS are not protocols associated with IPsec.

REFERENCES

LabSim for Network Pro, Section 13.7.

Question 16: ✔ Correct

You want to use CCTV to increase the physical security of your building. Which of the following camera types would offer the sharpest image at the greatest distance under the lowest lighting conditions?

- 500 resolution, 50mm, 2 LUX
- 400 resolution, 10mm, .05 LUX
- ➡ 500 resolution, 50mm, .05 LUX
- 400 resolution, 10mm, 2 LUX

EXPLANATION

When you select cameras, be aware of the following characteristics:

- The resolution is rated in the number of lines included in the image. In general, the higher the resolution, the sharper the image.
- The focal length measures the magnification power of a lens. The focal length controls the distance that the camera can see, as well as how much detail can be seen at a specific range. A higher focal length lets you see more detail at a greater distance.
- LUX is a measure of sensitivity to light. The lower the number, the less light is needed for a clear image.

REFERENCES

LabSim for Network Pro, Section 13.1.

Question 17: ✔ Correct

You want to allow traveling users to connect to your private network through the internet. Users will connect from various locations including airports, hotels, and public access points such as coffee shops and libraries. As such, you won't be able to configure the firewalls that might be controlling access to the internet in these locations.

Which of the following protocols would be most likely to be allowed through the widest number of firewalls?

- L2TP
- ➡ SSL
- IPsec
- PPPoE
- PPTP

EXPLANATION

Ports must be opened in firewalls to allow VPN protocols. For this reason, using SSL for the VPN often works through firewalls when other solutions do not because SSL uses port 443--a port that is often already open to allow HTTPS traffic. In addition, some NAT solutions do not work well with VPN connections.

PPTP uses port 1723. L2TP uses ports 1701 and 500. IPsec uses UDP port 500 for the key negotiation protocol (IKE).

PPP over Ethernet (PPPoE) is used for connections that have an always on state, such as DSL or fiber optic running Ethernet. PPPoE is a modification of PPP that allows the negotiation of additional parameters that are typically not present on a regular Ethernet network. ISPs typically implement PPPoE to control and monitor internet access over broadband links.

REFERENCES

LabSim for Network Pro, Section 13.6.

Question 18: ✔ Correct

You have just purchased a new network device and are getting ready to connect it to your network. Which of the following should you do to increase its security? (Select two.)

- [ ] Remove any backdoors
- [x] Apply all patches and updates
- [ ] Implement separation of duties
- [ ] Conduct privilege escalation
- [x] Change default account passwords

EXPLANATION

To secure new devices, apply all recent patches and updates and change the default user account passwords. For some systems, you can also increase security by changing the default account usernames. Default account names and passwords are well known and can be easily discovered.

A *backdoor* is an unprotected access method or pathway. Backdoors are added by attackers or programmers during development. Backdoors that are present on new devices are typically hard-coded and must be removed by editing the code.

Privilege escalation allows a user to take advantage of a software bug or design flaw in an application to gain access to system resources or additional privileges that are typically not available to normal users. *Separation of duties* is the concept of requiring more than one person's participation to complete a task. This helps prevent insider attacks because no one person has end-to-end control and no one person is irreplaceable.

REFERENCES

LabSim for Network Pro, Section 13.8.

Question 19: ✔ Correct

Which of the following best describes the ping of death exploit?

- ➡ An ICMP packet larger than 65,536 bytes
- Redirecting echo responses from an ICMP communication
- Sending multiple spoofed ICMP packets to the victim
- Partial IP packets with overlapping sequencing numbers

EXPLANATION

A ping of death exploit uses an ICMP packet that is larger than 65,536 bytes.

A teardrop attack uses partial IP packets with overlapping sequencing numbers. A smurf attack sends multiple spoofed ICMP packets to the victim. The ability to re-direct echo responses is a feature of ICMP that is often involved in malicious attacks.

REFERENCES

LabSim for Network Pro, Section 13.8.

Question 20: ✔ Correct

What is modified in the most common form of spoofing on a typical IP packet?

- Hash total
- Protocol type field value
- Destination address
- ➡ Source address

EXPLANATION

The most common form of spoofing on a typical IP packet is modification of the source address. In this way, the correct source device address is hidden.

Modifications of the destination address would be pointless because the packets would not be sent to the intended victim or target. Modification of the protocol type field value is not typical, but doing so would cause the recipient to process the contents of the packet under different protocol rules than what the actual contents should be processed under, such as processing the packet as a UDP packet when it is actually an IGMP packet. Modification of the hash total would cause the packet to be dropped when it reached its destination because the target's computation of the hash would not match the stated hash in the header, indicating that the integrity of the packet was compromised.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 21: ✔ Correct

A relatively new employee in the data entry cubical farm was assigned a user account similar to that of all of the other data entry employees. However, audit logs have shown that this user account has been used to change ACLs on several confidential files and has accessed data in restricted areas.

This situation indicates that which of the following has occurred?

- Man-in-the-middle attack
- Smurf attack
- ➡ Privilege escalation
- Social engineering

EXPLANATION

This situation describes the result of a successful privilege escalation attack. If a low-end user account is detected performing high-level activities, it is obvious that user account has somehow gained additional privileges.

A man-in-the-middle attack involves a third party placing themselves between two legitimate communication partners in order to intercept and possibly alter their transmissions. Social engineering attacks involve stealing information or convincing someone to perform a security-inappropriate activity via email or phone or in person. A smurf attack is a form of distributed reflective denial of service where spoofed ICMP packets are bounced and multiplied off another network to flood the communication pipeline of the victim.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 22: ✔ Correct

Which of the following describes a man-in-the-middle attack?

- Malicious code is planted on a system, where it waits for a triggering event before activating.
- ➡ A false server intercepts communications from a client by impersonating the intended server.
- An IP packet that is larger than the valid size is constructed .
- A person over the phone convinces an employee to reveal their logon credentials.

EXPLANATION

A false server intercepting communications from a client by impersonating the intended server is a form of a man-in-the-middle attack.

Convincing an employee over the phone to reveal his logon credentials is an example of a social engineering attack. Constructing an IP packet, which is larger than the valid size is a land attack (a form of DoS). Planting malicious code on a system where it waits for a triggering event before activating is a logic bomb.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 23: ✔ Correct

A VPN is used primarily for which purpose?

- Allow remote systems to save on long-distance charges.
- ➡ Support secured communications over an untrusted network.
- Support the distribution of public web documents.
- Allow the use of network-attached printers.

EXPLANATION

A VPN (virtual private network) is used primarily to support secured communications over an untrusted network. A VPN can be used over a local area network, across a WAN connection, over the internet, and even between a client and a server over a dial-up connection through the internet. All of the other items listed in this question are benefits or capabilities that are secondary to this primary purpose.

REFERENCES

LabSim for Network Pro, Section 13.7.

Question 24: ✕ Incorrect

You are an IT consultant and are visiting a new client's site to become familiar with their network. As you walk around their facility, you note the following:

- When you enter the facility, a receptionist greets you and escorts you through a locked door to the work area where the office manager sits.
- The office manager informs you that the organization's servers are kept in a locked closet. An access card is required to enter the server closet.
- The receptionist informs you that server backups are configured to run each night. A rotation of tapes are used as the backup media.
- You notice that the organization's network switch is kept in the server closet.
- You notice that a router/firewall/content filter all-in-one device has been implemented in the server closet to protect the internal network from external attacks.
- The office manager informs you that her desktop system will no longer boot and asks you to repair or replace it, recovering as much data as possible in the process. You carry the workstation out to your car and bring it back to your office to work on it.

Which security-related recommendation should you make to this client?

- Replace the tape drive used for backups with external USB hard disks.
- ~~Keep the network infrastructure devices (switch and all-in-one device) in a locked room separate from network servers.~~
- Upgrade the server closet lock to a biometric authentication system.
- Implement a hardware checkout policy.

EXPLANATION

In this scenario, you should recommend the client implement a hardware checkout policy. A checkout policy ensures that hardware containing sensitive data does not leave the organization's premises without approval and that the device's serial number, make, and model number are recorded.

A biometric server room lock probably isn't necessary in this scenario. It is acceptable to keep servers and network devices such as routers and switches in the same room as long as that room is kept secure. There's no security advantage to using external hard drives instead of tape backup media.

REFERENCES

LabSim for Network Pro, Section 13.1.

Question 25: ✔ Correct

Which of the following is a platform independent authentication system that maintains a database of user accounts and passwords that centralizes the maintenance of those accounts?

- NAS
- RRAS
- ➡ RADIUS
- EAP

EXPLANATION

The Remote Authentication Dial-In User Service (RADIUS) is an authentication system that allows the centralization of remote user account management.

The Routing and Remote Access Service (RRAS) is a software component on a Windows Server system that provides remote access capabilities for users. A network access server (NAS) is a server or other system that acts as a gateway for remote user connections. The NAS passes authentication requests to the RADIUS server, which then checks the credentials of the user attempting to connect. NAS is also an acronym for network attached storage. Extensible authentication protocol (EAP) is an authentication protocol that supports the use of devices such as smart cards. It does not maintain a database of user accounts and passwords.

REFERENCES

LabSim for Network Pro, Section 13.5.

Question 26: ✕ Incorrect

Which of the following is the main difference between a DoS attack and a DDoS attack?

- The DDoS attack uses zombie computers.
- The DDoS attack does not respond to SYN ACK packets in the three-way handshake process.
- ~~The DDoS attack uses an amplification network.~~
- The DDoS attack spoofs the source IP address.

EXPLANATION

While the term denial of service (DoS) is a generic term meaning many different types of attacks, in a DoS attack, a single attacker directs an attack at a single target, sending packets directly to the target. In a distributed DoS (DDoS) attack, multiple PCs attack a victim simultaneously. DDoS compromises a series of computers by scanning computers to find vulnerabilities and then capitalizing on the most vulnerable systems. In a DDoS attack:

- The attacker identifies one of the computers as the master (also known as zombie master or bot herder) .
- The master uses zombies/bots (compromised machines) to attack.
- The master directs the zombies to attack the same target.

A distributed reflective denial of service (DRDoS) uses an amplification network to increase the severity of the attack. Packets are sent to the amplification network addressed as coming from the target. The amplification network responds back to the target system.

Spoofed source addresses can be used with both DoS and DDoS attacks. A SYN flood is a form of DoS attack that does not complete the three-way handshake process. DDoS and even DRDoS attacks could use this method to overload the target system.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 27: ✔ Correct

How can an organization help prevent social engineering attacks? (Select two.)

- [x] Publish and enforce clearly written security policies
- [x] Educate employees on the risks and countermeasures
- [ ] Utilize 3DES encryption for all user sessions
- [ ] Implement IPsec on all critical systems

EXPLANATION

User training and policy enforcement are the keys to preventing social engineering attacks. Many users are not aware of social engineering risks. Training raises awareness, provides clear instructions for dealing with and reporting suspicious activity, and directly supports all published security policies.

Technical countermeasures protect against automated attacks. Social engineering seeks to gain access by exploiting human nature.

REFERENCES

LabSim for Network Pro, Section 13.2.

Question 28: ✔ Correct

Which of the following are denial of service attacks? (Select two.)

- [ ] Hijacking
- [x] Fraggle
- [x] Smurf
- [ ] Salami

EXPLANATION

Smurf and Fraggle are both denial of service attacks. Smurf spoofs the source address in ICMP packets and sends the ICMP packets to an amplification network (bounce site). The bounce site responds to the victim site with thousands of messages that he did not send. A Fraggle attack is similar to a Smurf attack, but uses UDP packets directed to port 7 (echo) and port 19 (chargen - character generation).

Salami is not a denial of service attack. A salami attack is a form of attack where a small amount of information, data, or valuables are taken over a period of time. The result is to construct or obtain data or property of great value. A common example of a salami attack is to deposit the fractions of cents from an accounting program into a numbered account. Eventually, the fraction deposits total a significant sum. Hijacking is an attack directed at authentication. Hijacking is the theft of an open and active communication session from a legitimate user (an extension of a man-in-the-middle attack). The attacker takes over the session and cuts off the original source device.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 29: ✔ Correct

An attacker captures packets as they travel from one host to another with the intent of altering the contents of the packets. Which type of attack is being executed?

- Spamming
- Passive logging
- ➡ Man-in-the-middle attack
- Distributed denial of service

EXPLANATION

Capturing packets between two existing communication partners is a form of man-in-the middle attack. This attack's name comes from the way traffic is intercepted somewhere between or in the middle of the two communicating partners. The best way to protect a system from man-in-the middle attacks is to use session encryption or line encryption solutions.

Passive logging is a means of recording information about network traffic or operations in a system without affecting either in any way.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 30: ✔ Correct

What is the primary benefit of CCTV?

- Increases security protection throughout an environment.
- Reduces the need for locks and sensors on doors.
- Provides a corrective control.
- ➡ Expands the area visible to security guards.

EXPLANATION

A primary benefit of CCTV is that it expands the area visible to security guards. This helps few guards oversee and monitor a larger area.

CCTV does not reduce the need for locks and sensors on doors. CCTV does not provide a corrective control (it is a preventative, deterrent, or detective control). CCTV does not increase security protection throughout an environment only in the area where it is aimed.

REFERENCES

LabSim for Network Pro, Section 13.1.

Question 31: ✔ Correct

If your anti-virus software does not detect and remove a virus, what should you try first?

- Search for and delete the file you believe to be infected.
- ➡ Update your virus detection software.
- Scan the computer using another virus detection program.
- Set the read-only attribute of the file you believe to be infected.

EXPLANATION

Virus detection software can search only for viruses listed in its known viruses data file. An outdated file can prevent the virus detection software from recognizing a new virus.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 32: ✔ Correct

You have installed anti-malware software that checks for viruses in email attachments. You configure the software to quarantine any files with problems.

You receive an email with an important attachment, but the attachment is not there. Instead, you see a message that the file has been quarantined by the anti-malware software.

What has happened to the file?

- It has been deleted from your system.
- ➡ It has been moved to a secure folder on your computer.
- The file extension has been changed to prevent it from running.
- The infection has been removed, and the file has been saved to a different location.

EXPLANATION

Quarantine moves the infected file to a secure folder, where it cannot be opened or run normally. By configuring the software to quarantine any problem files, you can view, scan, and possibly repair those files.

Quarantine does not automatically repair files. Deleting a file is one possible action to take, but this action removes the file from your system.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 33: ✔ Correct

What is spoofing?

- ➡ Changing or falsifying information in order to mislead or re-direct traffic
- Sending a victim unwanted and unrequested email messages
- Spying into private information or communications
- Capturing network packets in order to examine the contents of communications

EXPLANATION

Spoofing is the act of changing or falsifying information in order to mislead or re-direct traffic. For example, an email-based spoofing attack changes the source email address so that it is impossible to backtrack the message to its original source. Other examples of spoofing attacks are Smurf and Fraggle. These attacks send ICMP or UDP echo requests that have spoofed source addresses to an intermediary system. The echo responses are returned to the stated source address, which is not the real address of the sender, but the address of the intended victim. A land attack is another example of an attack that uses spoofing. A land attack is when a SYN packet, the first packet of the TCP three-way handshake, is sent to a server, but the source address is spoofed as the target server's address.

Snooping is the act of spying into private information or communications. One type of snooping is sniffing. Sniffing is the act of capturing network packets in order to examine the contents of communications. Spamming is sending a victim unwanted and unrequested email messages.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 34: ✔ Correct

While using the internet, you type the URL of one of your favorite sites in the browser. Instead of going to the correct site, the browser displays a completely different website. When you use the IP address of the web server, the correct site is displayed.

Which type of attack has likely occurred?

- ➡ DNS poisoning
- Spoofing
- Hijacking
- Man-in-the-middle

EXPLANATION

Because the correct site shows when you use the IP address, you know that the main website is still functional and that the problem is likely caused by an incorrect domain name mapping. DNS poisoning occurs when a name server receives malicious or misleading data that incorrectly maps host names and IP addresses. In a DNS poisoning attack:

- Incorrect DNS data is introduced into the cache of a primary DNS server.
- The incorrect mapping is made available to client applications through the resolver.

Spoofing is used to hide the true source of packets or redirect traffic to another location. Spoofing attacks use modified source and/or destination addresses in packets and can include site spoofing that tricks users into revealing information. A man-in-the-middle attack is used to intercept information passing between two communication partners. TCP/IP hijacking is an extension of a man-in-the-middle attack where the attacker steals an open and active communication session from a legitimate user. In spoofing, man-in-the-middle, and hijacking attacks, the attack would be successful regardless of whether the DNS name or the IP address were used.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 35: ✔ Correct

Which of the following is a text file that a website stores on a client's hard drive to track and record information about the user?

- Mobile code
- Digital signature
- ➡ Cookie
- Certificate

EXPLANATION

A cookie is a text file that a website provides to a client that is stored on a user's hard drive to track and record information about the user.

Mobile code is self-contained software that is transferred to a web client to be executed. It allows client-side execution of web applications. A certificate is a digital proof of identity used to establish or verify a user's identity over a network or the internet. A digital signature is a cryptographic tool that is used to prove who a message is from and that the contents of the message did not change or become altered while in transit.

REFERENCES

LabSim for Network Pro, Section 13.4.

Question 36: ✔ Correct

When a malicious user captures authentication traffic and replays it against the network later, what is the security problem you are most concerned about?

- ➡ An unauthorized user gaining access to sensitive resources
- Spam
- Denial of service
- Bandwidth consumption

EXPLANATION

When a malicious user captures authentication traffic and replays it against the network later, the security problem you are most concerned about is an unauthorized user gaining access to sensitive resources. Once a replay attack has been successful, the attacker has the same access to the system as the user from whom the authentication traffic was captured.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 37: ✔ Correct

What is the primary countermeasure to social engineering?

- A written security policy
- Traffic filters
- Heavy management oversight
- ➡ Awareness

EXPLANATION

The primary countermeasure to social engineering is awareness. If users are unaware of the necessity for security in your organization and they are not properly trained to support and provide security, they are vulnerable to numerous social engineering exploits. Awareness training focused on preventing social engineering should include methods for authenticating personnel over the phone, assigning classification levels to information and activities, and educating your personnel on what information should not be distributed over the phone.

A written security policy is a countermeasure against social engineering, but without awareness training, it is useless. Heavy management oversight may provide some safeguards that protect users from social engineering, but management is less effective than awareness. Traffic filters are not countermeasures for social engineering because they do not focus on solving the human problem inherent in social engineering attacks.

REFERENCES

LabSim for Network Pro, Section 13.2.

Question 38: ✔ Correct

You manage a network that uses switches. In the lobby of your building, there are three RJ45 ports connected to a switch.

You want to make sure that visitors cannot plug their computers into the free network jacks and connect to the network. But employees who plug into those same jacks should be able to connect to the network.

What feature should you configure?

- ➡ Port authentication
- Spanning tree
- VLANs
- Bonding
- Mirroring

EXPLANATION

Use port authentication to prevent unauthorized access through switch ports. Port authentication is provided by the 802.1x protocol and allows only authenticated devices to connect to the LAN through the switch. Authentication uses usernames and passwords, smart cards, or other authentication methods.

- When a device first connects, the port is set to an unauthorized state. Ports in unauthorized states can only be used for 802.1x authentication traffic.
- After the server authenticates the device or the user, the switch port is placed in an authorized state, and access to other LAN devices is allowed.

If you use a VLAN, you can assign each port to a VLAN. If the ports in the lobby were assigned to one VLAN, you could control the type of access through the switch for those ports, but could not modify the access based on user. Using a VLAN, both visitors and employees would have the same access through those ports.

Spanning tree is a protocol on a switch that allows the switch to maintain multiple paths between switches within a subnet. The spanning tree protocol runs on each switch and is used to select a single path between any two switches. Mirroring sends traffic from all switch ports to a switch port you designate as the mirrored port. Bonding allows multiple switch ports to be used at the same time to reach a specific destination.

REFERENCES

LabSim for Network Pro, Section 13.5.

Question 39: ✔ Correct

Which of the following is a form of attack that either exploits a software flaw or floods a system with traffic in order to prevent legitimate activities or transactions from occurring?

- ➡ Denial of service attack
- Privilege escalation
- Man-in-the-middle attack
- Brute force attack

EXPLANATION

A denial of service attack either exploits a software flaw or floods a system with traffic in order to prevent legitimate activities or transactions from occurring.

A brute force attack tries every valid key or code sequenced in an attempt to discover a password or encryption key. Brute force attacks will always be successful given enough time (however, enough time could be millennia). A man-in-the-middle attack involves a third party placing themselves between two legitimate communication partners in order to intercept and alter their transmissions. Privilege escalation is a user stealing or obtaining high-level privileges in a computer system.

REFERENCES

LabSim for Network Pro, Section 13.3.

Question 40: ✔ Correct

To tightly control the anti-malware settings on your computer, you elect to update the signature file manually. Even though you vigilantly update the signature file, the machine becomes infected with a new type of malware.

Which of the following actions would best prevent this scenario from occurring again?

- Create a scheduled task to run **sfc.exe**daily.
- Switch to a more reliable anti-virus software.
- Carefully review open firewall ports and close any unneeded ports.
- ➡ Configure the software to automatically download the virus definition files as soon as they become available.

EXPLANATION

Anti-malware software is most effective if it has the latest virus definition files installed. Instead of manually updating the signature files, you should configure the software to automatically download updated virus definition files as soon as they become available.

Use **sfc.exe** to repair infected files after malware has caused the damage. Using a different anti-virus software might help, but will not resolve the problem if you don't get the latest definition files.

REFERENCES

LabSim for Network Pro, Section 13.3.

Copyright © 2021 TestOut Corporation All rights reserved.